

Auftragsverarbeitungsvertrag

gemäß Art. 28 DSGVO · inkl. technischer und organisatorischer Maßnahmen

rentencheck.app · Stand: August 2026 · Version 2026-08

Auftragnehmer

Luisa Brandt, Ernst-Bähre-Str. 3, 30453 Hannover

Auftraggeber

Der bei rentencheck.app registrierte Nutzer als Unternehmer im Sinne des § 14 BGB. Der AVV wird mit der Registrierung Bestandteil des Nutzungsvertrags.

§ 1 Gegenstand und Dauer der Auftragsverarbeitung

Dieser Auftragsverarbeitungsvertrag (nachfolgend „AVV“) regelt die Verarbeitung personenbezogener Daten durch den Auftragnehmer (Anbieter der Plattform rentencheck.app, Luisa Brandt, Hannover) im Auftrag des Auftraggebers (registrierter Nutzer als Unternehmer i. S. d. § 14 BGB) im Rahmen der Nutzung der SaaS-Plattform.

Der AVV gilt für die Dauer des Nutzungsvertrags und endet automatisch mit dessen Beendigung. Bei Vertragsende werden alle personenbezogenen Daten des Auftraggebers innerhalb von 30 Tagen gelöscht, sofern keine gesetzliche Aufbewahrungspflicht besteht.

§ 2 Art und Zweck der Verarbeitung

Der Auftragnehmer verarbeitet personenbezogene Daten ausschließlich zur Bereitstellung der SaaS-Plattform für die modellhafte Simulation und Analyse von Altersvorsorge- und Investmentszenarien.

Eine Verarbeitung für eigene Zwecke des Auftragnehmers findet nicht statt. Die Verarbeitung erfolgt ausschließlich auf dokumentierte Weisung des Auftraggebers.

§ 3 Kategorien betroffener Personen und Datenkategorien

Folgende Datenkategorien können verarbeitet werden:

- Profildaten des Nutzers (Name, Unternehmen, E-Mail-Adresse)
- In Berechnungen eingegebene Parameterdaten (modellhafte Annahmen, keine echten Kundendaten erforderlich)
- Technische Zugriffsdaten (Session-Token, IP-Adresse, Browser-Informationen)

Hinweis: Die Plattform ist für modellhafte Simulationen ausgelegt. Es wird empfohlen, keine echten personenbezogenen Kundendaten einzugeben.

§ 4 Pflichten des Auftragnehmers

Der Auftragnehmer verpflichtet sich:

- Daten nur auf dokumentierte Weisung des Auftraggebers zu verarbeiten
- Zur Verschwiegenheit aller mit der Verarbeitung beauftragten Personen
- Alle erforderlichen technischen und organisatorischen Maßnahmen gemäß Art. 32 DSGVO zu ergreifen
- Subprozessoren nur nach vorheriger schriftlicher Genehmigung einzusetzen (Generalerlaubnis gemäß § 6 dieses AVV erteilt)
- Den Auftraggeber bei der Erfüllung von Betroffenenrechten zu unterstützen
- Den Auftraggeber unverzüglich zu informieren, sobald ihm eine Verletzung des Schutzes personenbezogener Daten bekannt wird, und ihn bei den Pflichten nach Art. 32 bis 36 DSGVO zu unterstützen (Art. 28 Abs. 3 lit. f DSGVO)
- Dem Auftraggeber alle zum Nachweis der Einhaltung dieser Pflichten erforderlichen Informationen zur

Verfügung zu stellen und Überprüfungen einschließlich Inspektionen zu ermöglichen und dazu beizutragen (Art. 28 Abs. 3 lit. h DSGVO)

- Den Auftraggeber unverzüglich zu informieren, wenn eine Weisung nach seiner Auffassung gegen die DSGVO oder andere Datenschutzvorschriften verstößt (Art. 28 Abs. 3 Satz 3 DSGVO)
- Nach Vertragsende alle Daten zu löschen oder zurückzugeben

§ 5 Pflichten des Auftraggebers

Der Auftraggeber verpflichtet sich:

- Den Auftragnehmer unverzüglich zu informieren, wenn in seinen Weisungen Fehler festgestellt werden
- Die Verarbeitung personenbezogener Daten im Rahmen der Plattform auf das notwendige Minimum zu beschränken
- Zugangsdaten vertraulich zu behandeln und nicht weiterzugeben
- Datenpannen, die seinen Verantwortungsbereich betreffen, unverzüglich zu melden

§ 6 Subprozessoren

Der Auftraggeber erteilt hiermit eine allgemeine Genehmigung für den Einsatz der nachfolgend genannten Subprozessoren. Der Auftragnehmer informiert den Auftraggeber über geplante Änderungen mit angemessener Vorlaufzeit.

Subprozessor	Zweck	Sitz / Server
Supabase Inc.	Datenbank, Authentifizierung	USA / EU (Frankfurt)
Vercel Inc.	Hosting, CDN	USA / EU (Frankfurt)
Stripe Inc.	Zahlungsabwicklung	USA / EU (Dublin)
Resend Inc.	Transaktionsmails	USA / EU
Functional Software, Inc. (Sentry)	Fehlerdiagnose, Stabilitätsüberwachung	USA / EU (Frankfurt)

Nicht als Subprozessor eingesetzt wird Formspree, Inc. (USA). Der Dienst stellt ausschließlich Rückmeldungen des Auftraggebers über das Feedback-Formular per E-Mail zu und erhält dabei keinen Zugriff auf Daten, die der Auftraggeber im Rahmen dieses AVV verarbeiten lässt.

Technische und organisatorische Maßnahmen

gemäß Art. 32 DSGVO

Zugangskontrolle

Authentifizierung über Supabase Auth (E-Mail + Passwort). Passwörter werden ausschließlich als bcrypt-Hash gespeichert. Row-Level-Security (RLS) stellt sicher, dass Nutzer nur auf eigene Daten zugreifen.

Transportverschlüsselung

Alle Verbindungen erfolgen ausschließlich über HTTPS/TLS 1.2+. Unverschlüsselte Verbindungen werden automatisch weitergeleitet.

Verschlüsselung ruhender Daten

Datenbank-Volumes bei Supabase sind AES-256-verschlüsselt.

Pseudonymisierung

Berechnungen und Profildaten werden unter UUIDs (User-IDs) gespeichert, nicht unter Klarnamen im Systemkontext.

Backup & Wiederherstellung

Tägliche automatische Backups durch Supabase mit Point-in-Time-Recovery. Wiederherstellungszeit (RTO) < 4 Stunden.

Incident-Management

Sicherheitsvorfälle werden gemäß Art. 33 DSGVO innerhalb von 72 Stunden an die zuständige Aufsichtsbehörde gemeldet. Betroffene Nutzer werden unverzüglich informiert.

Diese Maßnahmen werden regelmäßig überprüft und an den Stand der Technik angepasst. Der Auftragnehmer dokumentiert Änderungen und stellt sie dem Auftraggeber auf Anfrage zur Verfügung.